ТУСУР
TUSUR UNIVERSITY

Менеджмент инцидентов информационной безопасности

Управление информационной безопасностью. Лекция 2.12

16 Менеджмент инцидентов информационной безопасности

Раздел включает в себя 1 категорию и 7 мер обеспечения информационной безопасности:

16.1 Менеджмент инцидентов информационной безопасности и улучшений
Цель: Обеспечить последовательный и эффективный подход к менеджменту инцидентов ИБ, включая обмен информацией о событиях безопасности и недостатках.

- 16.1.1 Обязанности и процедуры
- 16.1.2 Сообщения о событиях информационной безопасности
- 16.1.3 Сообщение о недостатках информационной безопасности
- 16.1.4 Оценка и принятие решений в отношении событий информационной безопасности
- 16.1.5 Реагирование на инциденты информационной безопасности
- 16.1.6 Извлечение уроков из инцидентов информационной безопасности
- 16.1.7 Сбор свидетельств

Обязанности и процедуры

Должны быть установлены обязанности и процедуры менеджмента для обеспечения уверенности в быстром, эффективном и надлежащем реагировании на инциденты ИБ.

Цели управления инцидентами ИБ должны быть согласованы с руководством и должны гарантировать, что лица, ответственные за управление инцидентами ИБ, понимают приоритеты организации при обработке инцидентов ИБ.

Должны быть приняты во внимание следующие рекомендации для обязанностей и процедур по управлению инцидентами ИБ:

a) должны быть установлены обязанности по управлению, чтобы гарантировать, что следующие процедуры разработаны и должным образом доведены до сведения внутри организации:
   1) процедуры планирования и подготовки реагирования на инциденты;
   2) процедуры мониторинга, обнаружения, анализа и информирования о событиях и инцидентах безопасности;
   3) процедуры регистрации действий по управлению инцидентами;
   4) процедуры обращения с криминалистическими свидетельствами;
   5) оценка недостатков ИБ;
   6) процедуры реагирования, включая процедуры эскалации, контролируемого восстановления после инцидента и информирования персонала внутри организации, лиц за ее пределами, а также организаций;

Обязанности и процедуры

b) установленные процедуры должны обеспечивать, что:
   1) вопросы, связанные с инцидентами ИБ в организации, решает компетентный персонал;
   2) существуют контактные лица по вопросам обнаружения и информирования об инцидентах безопасности;
   3) поддерживаются соответствующие контакты с органами власти, внешними заинтересованными группами или форумами, которые занимаются вопросами, связанными с инцидентами ИБ;
c) процедуры оповещения должны включать в себя:
   1) подготовку форм оповещения о событиях безопасности для обеспечения действий по оповещению и для того, чтобы лица, сообщающие о нарушениях, могли запомнить все необходимые действия в случае, если произошло событие безопасности;
   2) процедуру, которая должна быть предпринята в случае, если произошло событие ИБ, например немедленное фиксирование всех деталей, таких как вид несоответствия или нарушения, произошедший отказ, сообщения на экране и незамедлительное оповещение контактных лиц, а также принятие скоординированных действий;
   3) ссылку на установленный формальный процесс принятия дисциплинарных мер к работникам, которые совершают нарушения безопасности;
   4) соответствующие процессы обратной связи для обеспечения того, чтобы лица, сообщающие о событиях безопасности, были уведомлены о результатах после решения и закрытия проблемы.

Сообщения о событиях информационной безопасности

ТУСУР
TUSUR UNIVERSITY

Требуется незамедлительно сообщать о событиях информационной безопасности по соответствующим каналам управления.

Все работники и подрядчики должны быть осведомлены о своей обязанности незамедлительно сообщать о событиях ИБ. Они должны быть также осведомлены о процедуре оповещения о событиях безопасности и контактных лицах, которым следует сообщать о событиях.

Ситуации, которые предполагают передачу сообщения о событии ИБ, включают в себя:

a) неэффективный контроль ИБ;
b) нарушение ожидаемого уровня целостности, конфиденциальности или доступности информации;
c) человеческие ошибки;
d) несоответствия политикам или руководствам;
e) нарушения мер физической безопасности;
f) неконтролируемые системные изменения;
g) неисправности программного или аппаратного обеспечения;
h) нарушения доступа.

Сбои или иное ненормальное поведение системы могут быть индикаторами атак на систему защиты или фактического нарушения защиты, и следовательно о них всегда необходимо сообщать как о событиях ИБ.

Сообщение о недостатках информационной безопасности

ТУСУР
TUSUR UNIVERSITY

Работники и подрядчики, использующие информационные системы и услуги организации, должны обращать внимание на любые замеченные или предполагаемые недостатки ИБ в системах или сервисах и сообщать о них.

Все работники и подрядчики должны незамедлительно сообщать о недостатках ИБ контактных лиц, чтобы предотвратить инциденты ИБ. Механизм оповещения должен быть максимально простым, доступным и работоспособным.

Работникам и подрядчикам должно быть рекомендовано не пытаться проверять предполагаемые недостатки безопасности. Тестирование недостатков может быть воспринято как потенциально неправильное использование системы, а также может повредить информационную систему или сервис и привести к юридической ответственности лица, выполняющего тестирование.

Оценка и принятие решений в отношении событий информационной безопасности

ТУСУР
TUSUR UNIVERSITY

Должна быть проведена оценка событий безопасности и принято решение, следует ли их классифицировать как инциденты ИБ.

Контактные лица по вопросам обнаружения и информирования об инцидентах должны оценивать каждое событие безопасности, используя согласованную шкалу классификации событий и инцидентов безопасности, и решать, следует ли классифицировать событие как инцидент ИБ. Классификация и распределение инцидентов по приоритетам может помочь в определении влияния и масштаба инцидента.

В тех случаях, когда в организации есть группа реагирования на инциденты ИБ, оценка и принятие решения могут быть переданы ей для подтверждения или повторной оценки.

Результаты оценки и принятых решений должны быть подробно зафиксированы с целью обращения к ним в будущем и проверки.

Реагирование на инциденты информационной безопасности

ТУСУР
TUSUR UNIVERSITY

Реагирование на инциденты ИБ должно осуществляться в соответствии с документально оформленными процедурами.

Реагирование на инциденты ИБ должно осуществляться назначенными контактными лицами и другими соответствующими лицами из числа самой организации или сторонних организаций.

Реагирование должно включать в себя следующее:

a) как можно более быстрый сбор свидетельств произошедшего;
b) проведение криминалистического анализа ИБ по мере необходимости;
c) эскалация, если требуется;
d) обеспечение того, что все выполняемые действия по реагированию соответствующим образом зарегистрированы для дальнейшего анализа;
e) информирование о факте инцидента ИБ или любых существенных деталях о нем других лиц из числа самой организации или сторонних организаций в соответствии с принципом "необходимого знания";
f) устранение недостатка(ов) ИБ, которые могут стать причиной или способствовать возникновению инцидента;
g) после того, как инцидент успешно отработан, необходимо формально закрыть и записать его.

Реагирование на инциденты информационной безопасности

После инцидента должен проводиться анализ для выявления первопричины инцидента.

Первоочередной целью реагирования на инцидент является возобновление "нормального уровня безопасности", а затем инициирование необходимого восстановления.

Извлечение уроков из инцидентов информационной безопасности

ТУСУР
TUSUR UNIVERSITY

Знания, приобретенные в результате анализа и урегулирования инцидентов ИБ, должны использоваться для уменьшения вероятности или влияния будущих инцидентов.

Должны быть внедрены механизмы, позволяющие количественно определять и отслеживать типы, объемы и стоимость инцидентов ИБ. Информация, полученная в результате оценки инцидентов ИБ, должна использоваться для выявления повторяющихся или значительных инцидентов.

Оценка инцидентов ИБ может указывать на необходимость в усилении или дополнении мер обеспечения ИБ для снижения частоты, ущерба и стоимости в будущем или может быть принята во внимание при пересмотре политики безопасности.

При должном внимании к аспектам конфиденциальности, истории про реальные инциденты ИБ могут быть использованы при обучении персонала в качестве примеров того, что может случиться, как реагировать на такие инциденты и как избежать их в будущем.

Сбор свидетельств

В организации должны быть определены и применяться процедуры для идентификации, сбора, получения и сохранения информации, которая может использоваться в качестве свидетельств.

Должны быть разработаны и затем выполняться внутренние процедуры при рассмотрении свидетельств с целью принятия мер дисциплинарного и юридического характера.

В общем случае эти процедуры должны обеспечивать процессы идентификации, сбора, получения и сохранения свидетельств в зависимости от типа носителей, устройств и состояния устройств, например включенных или выключенных. Процедуры должны учитывать:

a) цепочку поставок;
b) безопасность свидетельств;
c) безопасность персонала;
d) роли и обязанности задействованного персонала;
e) компетентность персонала;
f) документацию;
g) инструктаж.

Сбор свидетельств

Там, где это возможно, должна быть предусмотрена сертификация или другие соответствующие способы оценки квалификации персонала и инструментария для того, чтобы повысить ценность сохраненных свидетельств.

Криминалистические свидетельства могут выходить за пределы организации или границы юрисдикции. В таких случаях следует обеспечить, чтобы организация имела право собирать требуемую информацию в качестве криминалистических свидетельств. Должны быть учтены требования различных юрисдикций, чтобы максимально увеличить шансы на признание в соответствующих юрисдикциях.

Идентификация – процесс, включающий в себя поиск, распознавание и документирование возможного свидетельства.

Сбор – процесс сбора физических предметов, которые могут содержать потенциальные свидетельства.

Получение – процесс создания копии данных в рамках определенного набора.

Сохранение – процесс поддержания и защиты целостности и первоначального состояния потенциальных свидетельств.

Сбор свидетельств

Когда событие безопасности обнаружено впервые, может быть неясно, приведет ли это событие к судебному разбирательству. Следовательно, существует опасность, что необходимое свидетельство будет намеренно или случайно уничтожено до того, как выяснится серьезность инцидента. Рекомендуется заранее привлекать юриста или полицию к любым предполагаемым действиям юридического характера и прислушиваться к советам по поводу необходимых свидетельств.

ГОСТ Р ИСО/МЭК 27037-2014 содержит руководства по идентификации, сбору, получению и сохранению цифровых свидетельств.

ИСО/МЭК 27035

Подробное руководство по управлению инцидентами ИБ приведено в ИСО/МЭК 27035.

ISO/IEC TR 18044:2004 Information security incident management

ГОСТ Р ИСО/МЭК ТО 18044-2007 Менеджмент инцидентов информационной безопасности

> ISO/IEC 27035:2011 Information security incident management

> ISO/IEC 27035-1:2016 Part 1: Principles of incident management

> ISO/IEC 27035-1:2023 Part 1: Principles and process (Принципы и процесс)

ISO/IEC 27035-2:2016 Part 2: Guidelines to plan and prepare for incident response

> ISO/IEC 27035-2:2023 Part 2: Guidelines to plan and prepare for incident response (Руководство по планированию и подготовке к реагированию на инциденты)

ISO/IEC 27035-3:2020 Part 3: Guidelines for ICT incident response operations (Руководство по реагированию на инциденты, связанные с ИКТ)

ISO/IEC 27035-4:2024 Part 4: Coordination (Координация)

Этапы менеджмента инцидентов ИБ

Планирование и подготовка:

- политика менеджмента инцидентов ИБ и обязательства высшего руководства по отношению к ней;
- система менеджмента инцидентов ИБ;
- корпоративная безопасность и безопасность системы/сервиса/сети, анализ и менеджмент рисков, обновление политик;
- создание ГРИИБ;
- инструктажи и обучение по вопросам осведомленности об инцидентах ИБ;
- тестирование системы менеджмента инцидентов ИБ

Использование:

- обнаружение событий ИБ и оповещение (информирование) о них;
- оценка и принятие решения: является ли данное событие инцидентом ИБ;
- реагирование на инцидент ИБ, включая правовую экспертизу

Анализ:

- дополнительная правовая экспертиза;
- обобщение накопленного опыта;
- определение методов улучшения (повышения) безопасности;
- определение методов улучшения системы менеджмента инцидентов ИБ

Улучшение:

- провести уточнение результатов анализа рисков безопасности и анализа менеджмента;
- инициировать улучшение безопасноти;
- провести улучшения системы менеджмента инцидентов ИБ

ГОСТ Р ИСО/МЭК ТО 18044-2007

ISO/IEC 27035-1:2023

PLAN AND PREPARE

— Formulate and document information security incident management policies, and obtain commitment of top management
— Update information security policies, including those related to risk management,at both organization level and system, service, and network levels
— Develop and document an information security incident management plan
— Establish incident management team (IMT)
— Establish relationships and connections with internal and external organizations
— Determine technical and other support (including organizational and operational support)
— Plan and provide information security incident management awareness and skills training for all roles
— Test information security incident management plan

DETECT AND REPORT

— Collect situational awareness information from local environment and external data sources and news feeds
— Monitor systems and networks
— Detect and alert on anomalous, suspicious, or malicious activities
— Collect information security event reports from users, vendors, other IRTs or security organizations and automated sensors
— Report information security events

ASSESS AND DECIDE

— Assess information security event,and determine if it constitutes an information security incident
— Categorize, correlate and prioritize the incidents.
— Establish the necessary IRTs

RESPOND

— Investigate and determine whether information security incidents are under control
— Contain and eradicate information security incidents
— Invoke BCP/DRP measures for those incidents that exceed organizationally-determined limits for IRTs.
— Recover from information security incidents
— Resolve and close the information security incidents

LEARN LESSONS

— Identify, document and communicate the lessons learnt
— Identify and make improvements to information security
— Identify and make improvements to information security risk assessment and management review results
— Identify and make improvements to information security incident management policy and plan
— Evaluate the performance and effectiveness of the IRTs

Этапы менеджмента инцидентов ИБ (27035)

ТУСУР
TUSUR UNIVERSITY

PLAN AND PREPARE (Планирование и подготовка)

Этап является подготовительным и направлен на создание основ для эффективного реагирования на инциденты ИБ. Цель – обеспечить, чтобы организация была готова к инцидентам, что позволяет сократить время реакции и минимизировать ущерб.

DETECT AND REPORT (Обнаружение и оповещение)

На этапе выявляются потенциальные угрозы, но еще не классифицируются как инциденты. Цель – обеспечить своевременное выявление и первичный сбор информации о событиях безопасности и уязвимостях для их последующей оценки.

ASSESS AND DECIDE (Оценка и принятие решений)

На этапе определяется, является ли зарегистрированное событие инцидентом ИБ, требующим запуска формального процесса реагирования. Цель – быстро и обоснованно классифицировать событие, определить его приоритет и инициировать скоординированное реагирование.

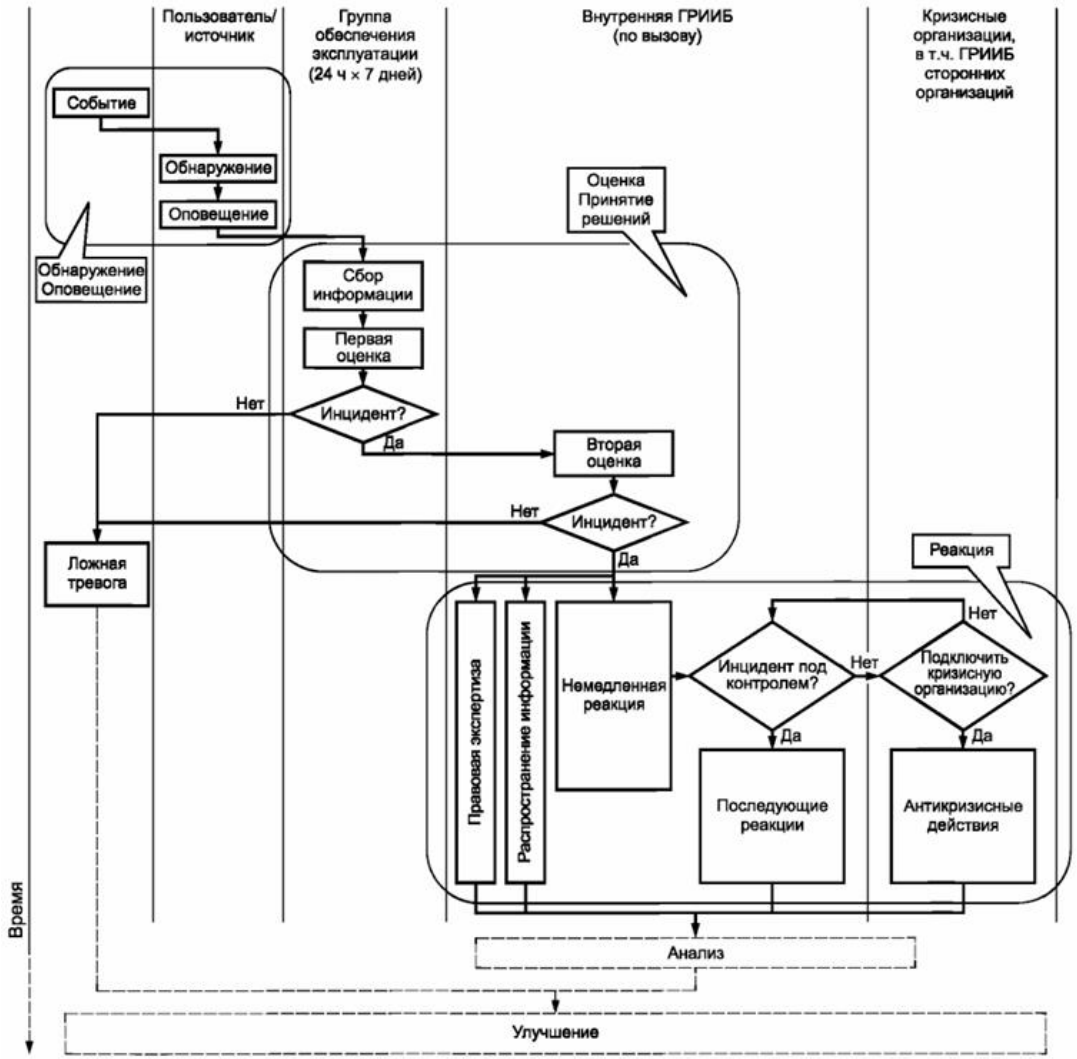
RESPOND (Реагирование)

На этапе выполняются действия по локализации, нейтрализации и ликвидации инцидента ИБ. Цель – минимизировать ущерб и восстановить нормальную работу затронутых систем или процессов в установленные сроки.

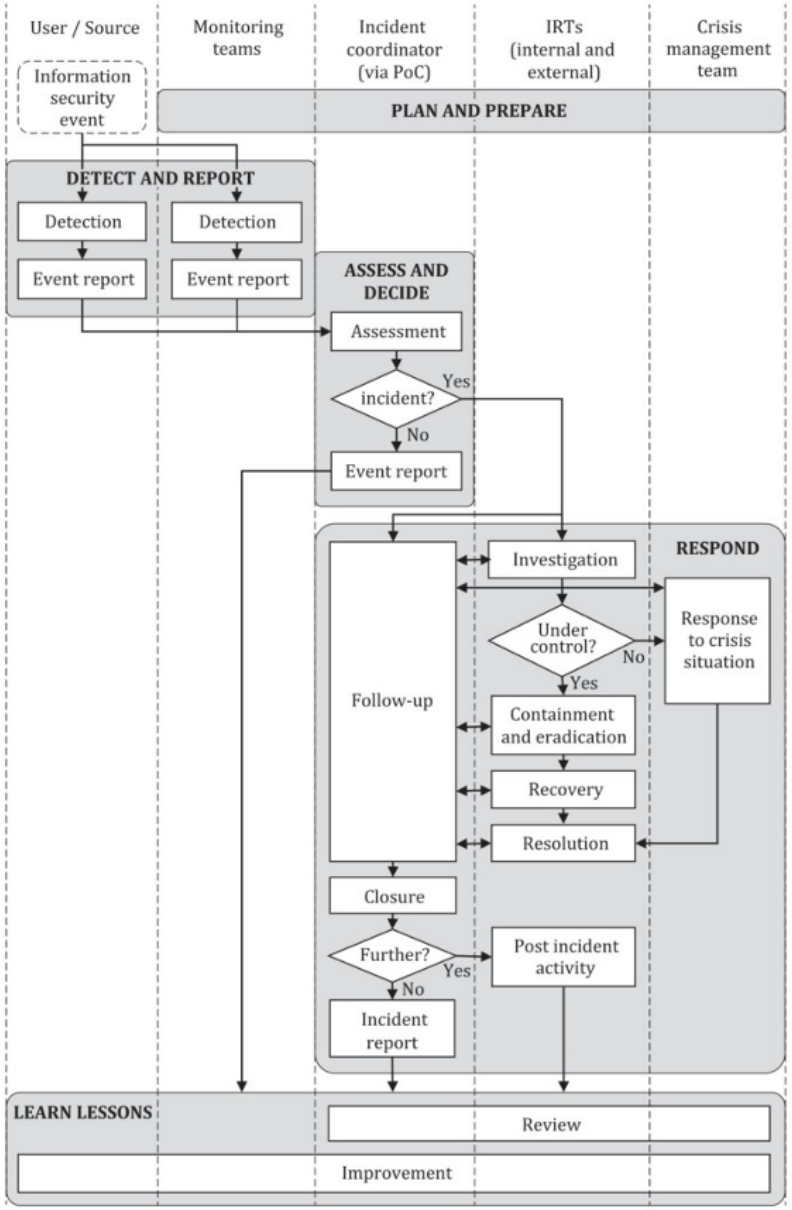
LEARN LESSONS (Извлечение уроков)

Заключительный аналитический этап цикла управления инцидентами. Цель – не просто закрыть инцидент, а проанализировать произошедшее, выявить причины и слабые места, чтобы повысить общий уровень безопасности организации и предотвратить повторение подобных событий.

Последовательность операций обработки событий и инцидентов ИБ

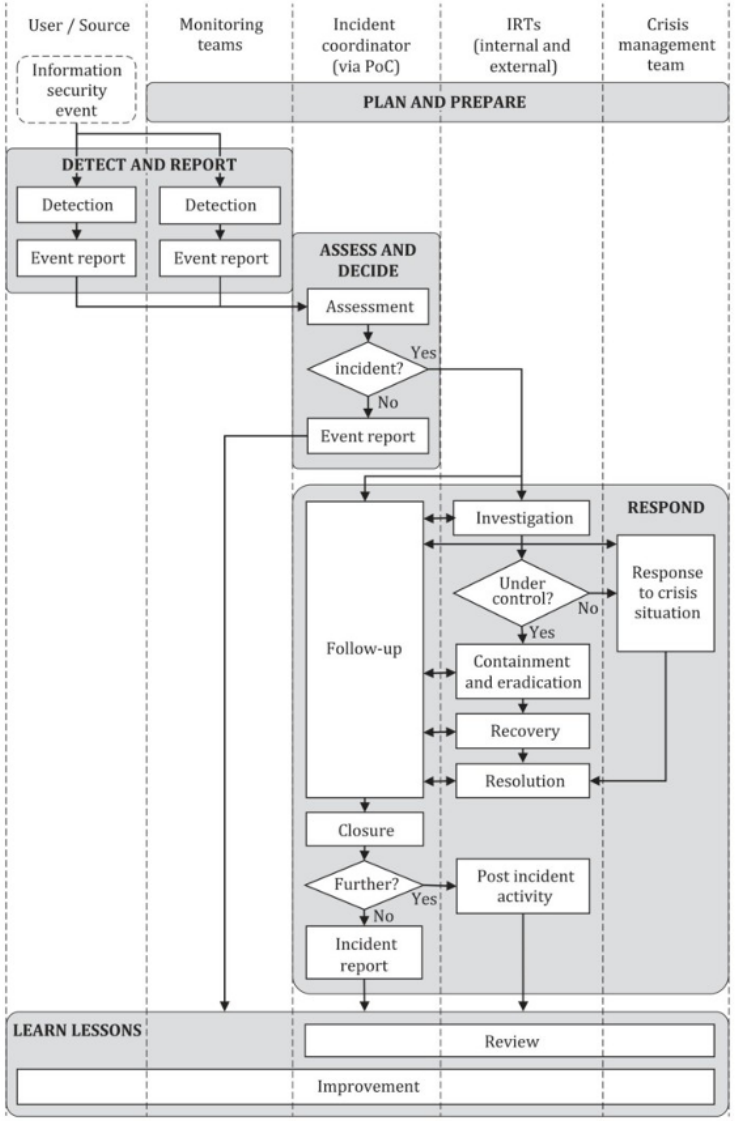


ГОСТ Р ИСО/МЭК ТО 18044-2007 (этап «Использование»)



ISO/IEC 27035-1:2023

Последовательность операций обработки событий и инцидентов ИБ



1. Процесс начинается с фазы Планирования и подготовки, которая является основой для всех последующих действий.
2. От различных источников поступает информация о событии ИБ.
3. На этапе Обнаружения событие выявляется и о нем составляется отчет.
4. На этапе Оценки определяется, является ли событие инцидентом (т.е. представляет ли реальную угрозу). Если нет, процесс завершается.
5. Если это инцидент, начинается Реагирование. Если ситуация не под контролем, то привлекается команда управления кризисными ситуациями. Если под контролем, сразу переходят к сдерживанию, ликвидации и восстановлению.
6. После разрешения инцидент закрывается.
7. Решается, нужны ли дальнейшие действия (пост-инцидентные). Если нет – формируется отчет.
8. Финальная фаза – Извлечение уроков, где проводится анализ всего процесса и вносятся улучшения.

Адаптируемость

Если организация полностью внедрит рекомендации стандартов 27035, то для функционирования и управления системой управления инцидентами могут потребоваться значительные ресурсы.

Для организаций, применяющих 27035, важно обеспечивать чтобы ресурсы, выделяемые на управление инцидентами ИБ, и сложность внедряемых механизмов были соразмерны следующим факторам:

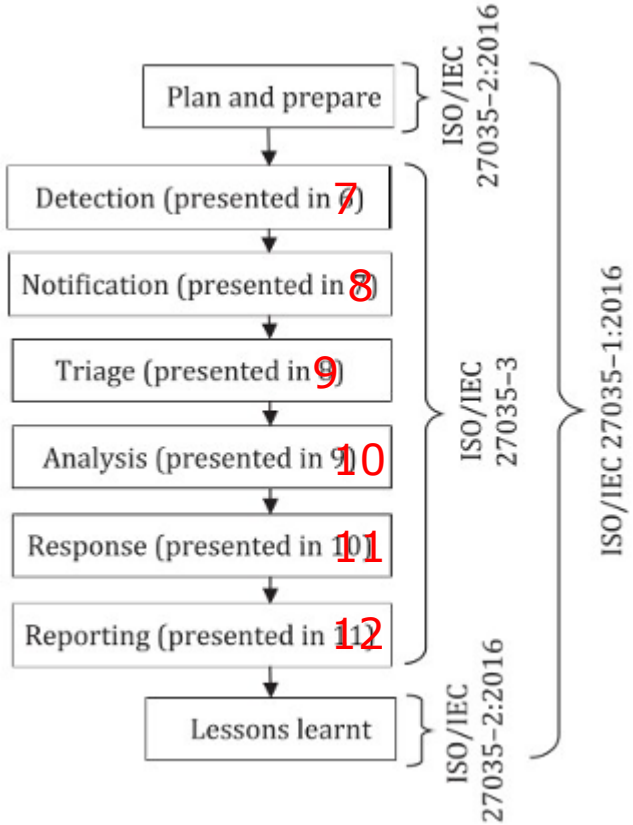
a) Размеру, структуре и характеру бизнеса организации, включая ключевые важные активы, процессы и данные, которые необходимо защищать.
b) Области действия любой системы менеджмента ИБ для обработки инцидентов.
c) Потенциальному риску, обусловленному инцидентами.
d) Целям бизнеса.

27035 – это библиотека передовых практик. «Слепое» внедрение без учета контекста может привести к созданию неподъемной, громоздкой и экономически неэффективной системы.

Простыми словами: *Не нужно строить ядерный бункер, если вам угрожает дождь. Возьмите зонт. Если, конечно, дождь не метеоритный.*

Связь между стандартами 27035

В 27035-3 этапы процесса управления инцидентами отличаются от описанных в 27035-1, однако не противоречат им, а дополняют и конкретизируют.



27035-3	27035-1
1. Планирование и подготовка.	
2. Обнаружение (выявления событий ИБ). 3. Уведомление (информирование о событии).	Обнаружение и оповещение
4. Первичная сортировка (первоначальная оценка и приоритизация). 5. Анализ (детальное изучение инцидента).	Оценка и принятие решений
6. Реагирование (выполнение действий по устранению инцидента). 7. Отчетность (документирование и предоставление отчетов).	Реагирование
8. Извлечение уроков (анализ и совершенствования процессов).	

Планирование и подготовка

- Формулировка и документирование политик управления инцидентами ИБ, получение поддержки высшего руководства.
- Обновление политик ИБ, включая политики управления рисками на как на уровне организации, так и для систем, сервисов и сетей.
- Разработка и документирование плана управления инцидентами ИБ.
- Создание группы реагирования на инциденты.
- Установление отношений и связей внутри организации и с внешними организациями.
- Определение технической и иной поддержки (включая организационную и операционную).
- Планирование и проведение обучения по повышению осведомленности и навыков в области управления инцидентами ИБ для всех ролей.
- Тестирование плана управления инцидентами ИБ.

Итог реализации этапа: Организация переходит от концепции к состоянию оперативной готовности, имея документированные, согласованные и отработанные процессы для управления инцидентами ИБ.

Обнаружение и оповещение

- Сбор информации из локальных и внешних источников данных, новостных лент.
- Мониторинг систем и сетей.
- Обнаружение и оповещение об аномальной, подозрительной или вредоносной активности.
- Сбор отчетов о событиях ИБ от пользователей, поставщиков, других групп реагирования, организаций безопасности и автоматизированных сенсоров.
- Оповещение о событиях ИБ.

Итог этапа: Получение первичного сигнала о событии безопасности, сбор начального набора данных и их централизованная регистрация в реестре инцидентов.

Оценка и принятие решений

- Оценка события ИБ и определение, является ли оно инцидентом ИБ.
- Категоризация, корреляция и приоритизация инцидентов.
- Создание необходимых групп реагирования (IRT).

Итог этапа: Событие получает официальный статус (инцидент или ложное срабатывание). В случае инцидента процесс переходит от пассивного наблюдения к активному управлению: назначены ответственные, запущен счетчик времени, задействованы ресурсы для перехода к следующей фазе.

Реагирование

- Расследование и определение, находятся ли инциденты ИБ под контролем.
- Сдерживание и ликвидация инцидентов ИБ.
- Применение мер BCP/DRP (План обеспечения непрерывности бизнеса / План аварийного восстановления) для тех инцидентов, которые превышают установленные организацией пределы для групп реагирования.
- Восстановление после инцидентов ИБ.
- Разрешение и закрытие инцидентов ИБ.

Итог этапа: Инцидент взят под контроль, непосредственное воздействие прекращено, а основные затронутые сервисы восстановлены.

Извлечение уроков

- Выявление, документирование и передача извлеченных уроков.
- Выявление и внесение улучшений в сферу информационной безопасности.
- Выявление и внесение улучшений в систему оценки рисков ИБ и процесс оценки деятельности.
- Выявление и внесение улучшений в политику и план управления инцидентами ИБ.
- Оценка производительности и эффективности групп реагирования (IRT).

Итог этапа: Цикл управления инцидентом завершен. На основе конкретного опыта сформирован план совершенствования, который приводит к:

- Обновлению плана управления инцидентами ИБ.
- Повышению зрелости процессов безопасности.
- Усилению защищенности активов.
- Снижению вероятности и потенциального ущерба от будущих инцидентов.

Этап замыкает цикл «Plan-Do-Check-Act» (PDCA), обеспечивая непрерывное развитие системы безопасности организации.

Рассмотренные вопросы

ТУСУР
TUSUR UNIVERSITY

Менеджмент инцидентов информационной безопасности:

- Обязанности и процедуры в области реагирования на инциденты ИБ
- Сообщения о событиях и о недостатках ИБ. Оценка и принятие решений в отношении событий ИБ и реагирование на инциденты ИБ

- Этапы менеджмента инцидентов ИБ
- Последовательность операций обработки событий и инцидентов ИБ

Почитать

- ГОСТ Р ИСО/МЭК 27002-2021
- ГОСТ Р ИСО/МЭК ТО 18044-2007
- ISO/IEC 27035
- Построение процесса реагирования на инциденты информационной безопасности: базовые принципы

https://rezbez.ru/article/postroenie-proczessa-reagirovaniya-na-inczidenty-informaczionnoj-bezopasnosti-bazovye-princzipy

ТУСУР
TUSUR UNIVERSITY

Всем спасибо – все свободны,

если нет вопросов!